



UNIVERSIDAD TECNOLÓGICA DE QUERÉTARO

Ingeniería
En Desarrollo y Gestión de Software

Seguridad en el desarrollo de aplicaciones

Grupo IDGS17

Nombre del alumno:
Jovanny Guadalupe López Cebreros

Matricula:
2023371119

Profesor:
Gerardo Ramírez Villareal

Práctica Logs

(SEGG-U2-P3G-2)

1. Objetivo de la Práctica

El objetivo principal de esta actividad fue instrumentar todos los controladores de la aplicación utilizando ILogger<T> siguiendo buenas prácticas de desarrollo seguro.

2. Alcance de la Instrumentación

Se implementó la inyección de dependencias con Serilog en los cinco controladores principales del sistema: HomeController , SearchController , AuthController , CommentController y ApiController.

Para asegurar una trazabilidad completa, cada acción fue configurada para registrar de manera estandarizada los siguientes elementos:

- **Identificación:** Registro del Usuario y la dirección IP de origen.
- **Ciclo de vida:** Eventos de Entrada y Salida de cada petición.
- **Rendimiento:** Medición exacta del Tiempo de ejecución mediante la clase Stopwatch.
- **Datos:** Registro de Parámetros (omitiendo estrictamente las contraseñas).
- **Seguridad y Errores:** Registro de Warnings , Errores , Excepciones y Eventos de autenticación.

3. Reporte de Hallazgos

Durante la ejecución de las pruebas y la validación en el servidor centralizado (Seq), se determinaron los siguientes hallazgos de seguridad y monitoreo:

- **Hallazgo 1: Protección de Datos Sensibles (Data Masking).** Al realizar pruebas en el módulo de inicio de sesión (AuthController), se validó con éxito que el sistema registra los intentos de acceso y el nombre de usuario, pero **no se registran contraseñas** en ningún nivel de log (ni en texto plano ni cifrado). Esto previene fugas de información en los archivos de auditoría.
- **Hallazgo 2: Monitoreo de Tiempos de Respuesta.** Gracias a la instrumentación con Stopwatch, ahora es posible identificar en Seq (filtrando por la propiedad ElapsedMilliseconds) cuáles endpoints están tardando más de lo esperado, facilitando la detección de posibles ataques de denegación de servicio (DoS) o cuellos de botella en la base de datos.
- **Hallazgo 3: Visibilidad de Intentos No Autorizados.** Al instrumentar el ApiController y el AuthController con eventos de nivel Warning, el sistema ahora alerta inmediatamente si un usuario intenta forzar el acceso a recursos sin una sesión válida (Error 401) o si intenta acceder a datos de otros perfiles (Error 403).
- **Hallazgo 4: Resiliencia ante Fallos.** Todos los controladores fueron envueltos en bloques try-catch. Esto garantiza que, si ocurre una excepción no controlada, el error exacto (con su *stack trace*) se registre automáticamente en Seq bajo el nivel Error, permitiendo al equipo de desarrollo diagnosticar el problema sin que la aplicación se detenga abruptamente.